PACOTE DE DUE DILIGENCE DE SEGURANÇA

Nexaflow ERP

Documentação de suporte ao questionário de segurança da informação enviado pela CloudFlux

Campo	Informação
Fornecedor	Nexaflow Sistemas Ltda. - CNPJ 12.345.678/0001-90
Cliente solicitante	CloudFlux
Responsável comercial	Rafael Souza - Executivo de Contas Sênior
Data de emissão	09/11/2026
Bloco	1 de 2 (documentos de divulgação padrão). O Bloco 2 (documentos sob NDA) será enviado após a assinatura do Acordo de Confidencialidade.

Índice

Doc.	Documento	Referência no questionário
1	Certificado ISO/IEC 27001:2022	Domínio 1 - Governança (item 2)
2	Procedimento de MFA para colaboradores internos	Domínio 2 - Gestão de Acesso (item 2)
3	Guia de funcionalidade: MFA na plataforma (ambiente do cliente)	Domínio 2 - Gestão de Acesso (item 2)
4	Procedimento de revogação de acessos no desligamento	Domínio 2 - Gestão de Acesso (item 3)
5	Modelo padrão de DPA (Acordo de Processamento de Dados)	Domínio 8 - LGPD (item 2)
6	Comprovação de teste de intrusão e Resumo Executivo	Domínio 7 - Conformidade (item 1)
7	Acordo de Confidencialidade (NDA) - assinado	Assinado em 09/11/2026

Os documentos 1 a 6 são de divulgação padrão a clientes e prospects. Os documentos referentes a continuidade de negócios/DR, resposta a incidentes e controle de acesso interno serão disponibilizados no Bloco 2, mediante NDA assinado.

DOCUMENTO 1

Certificado de Conformidade ISO/IEC 27001:2022

Campo	Informação
Certificado nº	BR-ISMS-2024-0471
Organização certificada	Nexaflow Sistemas Ltda.
Organismo certificador	CertBR Auditoria e Certificação Ltda.
Norma	ABNT NBR ISO/IEC 27001:2022 - Sistema de Gestão de Segurança da Informação
Data da certificação inicial	12/09/2024
Validade do certificado	11/09/2027 (auditorias de manutenção anuais)
Declaração de Aplicabilidade	Versão 3.2, de 02/2026

Escopo da certificação

Desenvolvimento, manutenção e evolução do software ERP Nexaflow, conforme Declaração de Aplicabilidade vigente.

Local(is) abrangido(s) pelo escopo

Unidade de Desenvolvimento - Campinas/SP.

Declaração do organismo certificador

Certifica-se que o sistema de gestão de segurança da informação da organização acima identificada foi auditado e considerado em conformidade com os requisitos da norma ISO/IEC 27001:2022, para o escopo e locais acima descritos. Este certificado permanece válido enquanto forem cumpridas as auditorias de manutenção e as condições do contrato de certificação.

DOCUMENTO 2

Procedimento de MFA para Colaboradores Internos

Código: NX-SEG-PRO-009 | Versão 3.0 | Vigência: 03/2026

1. Objetivo

Definir a exigência e o fluxo de autenticação multifator (MFA) para colaboradores da Nexaflow no acesso a sistemas corporativos e a ambientes do produto.

2. Escopo

Aplica-se aos colaboradores com acesso aos ambientes de desenvolvimento, homologação e produção do Nexaflow ERP e aos administradores de infraestrutura.

3. Regra

O MFA é **obrigatório** para os seguintes acessos:

Acesso	Método exigido
Diretório corporativo / login único (SSO)	Aplicativo autenticador (TOTP)
VPN corporativa	Aplicativo autenticador (TOTP)
Repositórios de código e esteira de integração e entrega (CI/CD)	Aplicativo autenticador (TOTP)
Console de nuvem (AWS) e acessos administrativos de produção	Chave de segurança física (FIDO2)

4. Passo a passo para novos colaboradores

Etapa	Atividade	Responsável
1	RH registra a admissão e abre chamado de criação de acessos	Recursos Humanos
2	TI cria a conta no diretório corporativo com perfil de acordo com a função	Tecnologia da Informação
3	No primeiro login, o colaborador é obrigado a cadastrar o MFA; sem o cadastro, o acesso não é liberado	Colaborador
4	Para perfis administrativos, TI entrega e registra a chave de segurança física	Tecnologia da Informação
5	TI confirma o cadastro e encerra o chamado	Tecnologia da Informação

5. Perda ou troca de dispositivo

O colaborador abre chamado com a TI, que valida a identidade com o gestor imediato antes de redefinir o MFA. A redefinição é registrada no chamado.

6. Exceções

Contas de serviço (não interativas) não utilizam MFA e seguem controle específico de rotação de credenciais.

7. Revisão

Este procedimento é revisado anualmente pelo Gerente de Segurança da Informação. A aderência é verificada nas auditorias internas.

DOCUMENTO 3

Guia de Funcionalidade: MFA na Plataforma (Ambiente do Cliente)

Nexaflow ERP - Documentação do Produto - Versão 8.4

1. Visão geral

A Autenticação Multifator (MFA) adiciona uma segunda etapa de verificação no login dos usuários da plataforma, além de usuário e senha. O recurso está disponível para todos os planos e todos os módulos do Nexaflow ERP.

2. Métodos suportados

Aplicativo autenticador (TOTP), compatível com os principais aplicativos de mercado, e códigos de recuperação de uso único.

3. Como ativar

A configuração é realizada pelo **Administrador do ambiente do cliente**, no caminho: *Configurações* > *Segurança* > *Autenticação* > *Autenticação Multifator*. O administrador pode:

Opção	Descrição
Ativar para todos os usuários	Exige MFA no próximo login de todos os usuários do ambiente.
Ativar por perfil de acesso	Exige MFA apenas para os perfis selecionados (ex.: Financeiro, Administrador).
Deixar opcional	Cada usuário decide se ativa o MFA na própria conta.

4. Configuração padrão

Em novos ambientes, a configuração padrão é a de **MFA opcional**, até que o administrador defina a política de autenticação do ambiente. A Nexaflow recomenda a ativação para todos os usuários, em especial para perfis administrativos e financeiros.

5. Observações

A política de autenticação do ambiente é de responsabilidade do cliente, conforme o Modelo de Responsabilidade Compartilhada descrito nos Termos de Uso do serviço.

DOCUMENTO 4

Procedimento de Revogação de Acessos no Desligamento

Código: NX-SEG-PRO-014 | Versão 2.1 | Vigência: 01/2026

1. Objetivo

Estabelecer o fluxo de revogação de acessos lógicos de colaboradores desligados da Nexaflow, reduzindo o risco de acesso indevido a sistemas e informações.

2. Fluxo

Etapa	Atividade	Responsável	Prazo
1	Registro do desligamento no sistema de RH e abertura automática de chamado de revogação	Recursos Humanos	No dia do desligamento
2	Desativação da conta no diretório corporativo e encerramento de sessões ativas	Tecnologia da Informação	Até 24 horas
3	Revogação de acessos a sistemas internos e repositórios de código	Tecnologia da Informação	Até 24 horas
4	Recolhimento de equipamentos e credenciais físicas	Gestor imediato / Facilities	Até 5 dias úteis
5	Fechamento do chamado e registro de conclusão	Tecnologia da Informação	Até 5 dias úteis

3. Registros

O chamado de revogação fica registrado na ferramenta de gestão de serviços de TI da Nexaflow e é retido conforme a política de gestão de registros.

4. Revisão

Este procedimento é revisado anualmente pelo Gerente de Segurança da Informação.

DOCUMENTO 5

Modelo Padrão de Acordo de Processamento de Dados (DPA)

Anexo ao Contrato de Licenciamento e Prestação de Serviços Nexaflow ERP - Modelo padrão v4.0

Cláusula 1 - Definições e papéis

1.1. Para os fins deste Anexo, o CLIENTE atua como **Controlador** e a NEXAFLOW atua como **Operadora** dos dados pessoais tratados no âmbito da prestação dos serviços, nos termos da Lei nº 13.709/2018 (LGPD).

Cláusula 2 - Finalidade e instruções

2.1. A NEXAFLOW tratará os dados pessoais exclusivamente para a prestação dos serviços contratados e conforme as instruções documentadas do CLIENTE.

Cláusula 3 - Confidencialidade

3.1. A NEXAFLOW garante que as pessoas autorizadas a tratar os dados pessoais estão sujeitas a obrigação de confidencialidade.

Cláusula 4 - Medidas de segurança

4.1. A NEXAFLOW adotará medidas técnicas e administrativas aptas a proteger os dados pessoais contra acessos não autorizados e situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão, em conformidade com o art. 46 da LGPD e com as práticas de segurança descritas em sua Política de Segurança da Informação.

Cláusula 5 - Suboperadores

5.1. A NEXAFLOW poderá contratar suboperadores para a prestação dos serviços, mantendo lista atualizada disponível em seu portal de transparência. 5.2. A NEXAFLOW firmará com os suboperadores contratos que contenham obrigações de proteção de dados compatíveis com as deste Anexo.

Cláusula 6 - Incidentes de segurança

6.1. Em caso de incidente de segurança que envolva dados pessoais do CLIENTE, a NEXAFLOW comunicará o CLIENTE **em até 5 (cinco) dias úteis** após a confirmação do incidente, informando, quando disponíveis, a natureza dos dados afetados e as medidas adotadas.

Cláusula 7 - Direitos dos titulares

7.1. A NEXAFLOW auxiliará o CLIENTE, na medida do possível, no atendimento às solicitações dos titulares de dados.

Cláusula 8 - Auditoria

8.1. A NEXAFLOW disponibilizará ao CLIENTE, mediante solicitação, relatórios e certificações que comprovem a conformidade com este Anexo.

Cláusula 9 - Término do contrato

9.1. Encerrado o contrato, a NEXAFLOW devolverá ou eliminará os dados pessoais do CLIENTE em até 90 (noventa) dias, salvo obrigação legal de conservação.

DOCUMENTO 6

Comprovação de Teste de Intrusão e Resumo Executivo

Parte A - Atestado de realização

Campo	Informação
Empresa executora	SecTest Consultoria em Segurança Ltda.
Tipo de teste	Teste de intrusão externo (caixa cinza)
Alvo	Aplicação web e APIs do Nexaflow ERP (ambiente de produção e homologação)
Período de execução	07/07/2026 a 24/07/2026
Data de emissão do relatório	07/08/2026
Próxima execução prevista	07/2027 (ciclo anual)

Parte B - Resumo Executivo

Objetivo. Avaliar a postura de segurança da aplicação Nexaflow ERP frente a ameaças externas, com base em metodologias reconhecidas de mercado (OWASP Web Security Testing Guide e OWASP API Security Top 10).

Metodologia. Reconhecimento, mapeamento de superfície de ataque, análise de autenticação e autorização, testes de entrada de dados e lógica de negócio, e tentativa controlada de exploração.

Resultado geral. Durante o período de testes foram identificadas vulnerabilidades classificadas em diferentes níveis de severidade. A Nexaflow recebeu o relatório técnico completo e conduz o tratamento dos achados por meio de plano de ação interno, de acordo com a priorização de risco.

Conclusão. A aplicação apresenta nível de maturidade de segurança compatível com o de soluções ERP SaaS de mercado. Recomenda-se a manutenção do ciclo anual de testes.

Nota: o relatório técnico completo, com a descrição detalhada dos achados, é documento confidencial da Nexaflow e não é compartilhado com terceiros.

DOCUMENTO 7

Acordo de Confidencialidade (NDA) - Versão assinada

Pelo presente instrumento particular, de um lado **NEXAFLOW SISTEMAS LTDA.**, CNPJ 12.345.678/0001-90, com sede em Campinas/SP, doravante "NEXAFLOW"; e, de outro, **CLOUDFLUX**, doravante "CLOUDFLUX", (em conjunto, "Partes"), resolvem celebrar o presente Acordo de Confidencialidade, mediante as cláusulas seguintes:

Cláusula 1 - Objeto

1.1. O presente Acordo tem por objeto a proteção das informações confidenciais que a NEXAFLOW divulgar à CLOUDFLUX no contexto do processo de avaliação de segurança para eventual contratação dos serviços Nexaflow ERP ("Finalidade").

Cláusula 2 - Informações Confidenciais

2.1. Consideram-se Informações Confidenciais todas as informações, documentos, procedimentos, planos, relatórios e dados, de qualquer natureza ou formato, técnicos, comerciais ou de segurança, que forem divulgados pela NEXAFLOW, incluindo, mas não se limitando a, planos de continuidade de negócios, procedimentos de resposta a incidentes e documentos de controle de acesso.

Cláusula 3 - Obrigações da CLOUDFLUX

3.1. A CLOUDFLUX obriga-se a (i) utilizar as Informações Confidenciais exclusivamente para a Finalidade; (ii) não divulgá-las a terceiros sem autorização prévia e por escrito da NEXAFLOW; (iii) restringir o acesso a seus colaboradores e assessores que dele necessitem para a Finalidade e que estejam sujeitos a obrigações de confidencialidade equivalentes.

Cláusula 4 - Exceções

4.1. Não se consideram Informações Confidenciais aquelas que (i) sejam ou venham a ser de domínio público sem violação deste Acordo; (ii) já fossem licitamente conhecidas pela CLOUDFLUX; ou (iii) devam ser divulgadas por força de lei ou decisão de autoridade competente, caso em que a CLOUDFLUX notificará previamente a NEXAFLOW, quando permitido.

Cláusula 5 - Prazo

5.1. Este Acordo vigora por 2 (dois) anos a contar da data de assinatura, independentemente da celebração do contrato de prestação de serviços entre as Partes.

Cláusula 6 - Devolução e eliminação

6.1. Mediante solicitação da NEXAFLOW ou ao final da avaliação, a CLOUDFLUX devolverá ou eliminará as Informações Confidenciais recebidas, mantendo-se as obrigações de confidencialidade.

Cláusula 7 - Penalidades

7.1. O descumprimento deste Acordo sujeitará a parte infratora ao pagamento de perdas e danos apurados, sem prejuízo de outras medidas cabíveis.

Cláusula 8 - Foro

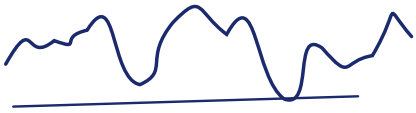
8.1. Fica eleito o foro da Comarca de Campinas/SP para dirimir quaisquer controvérsias decorrentes deste Acordo.

Campinas/SP, 09 de novembro de 2026.

NEXAFLOW SISTEMAS LTDA.

Nome: Eduardo Prado Lacerda
Cargo: Diretor Jurídico e de Compliance

CLOUDFLUX



Nome: Marina Albuquerque Teles
Cargo: Gerente Jurídica

Arquivo fictício produzido exclusivamente para fins de simulação do Projeto 10 (GRC - Gestão de Risco de Terceiros). Nexaflow Sistemas Ltda., seus colaboradores, documentos e certificações são fictícios e não representam nenhuma empresa real.